Université Cadi Ayyad Faculté des Sciences et Techniques

Rapport de Stage en Cybersécurité

Simulation d'attaque et détection d'intrusion avec Kali Linux, Metasploitable et Security Onion

Élèves :
Salma Bender

Encadrant :
SADQI Yassine

Année Universitaire 2024-2025

Remerciements

Je tiens à exprimer ma sincère reconnaissance à toutes les personnes qui ont contribué, de près ou de loin, à la réussite de ce projet.

Mes remerciements s'adressent à Monsieur SADQI Yassine, responsable de la filière SIT, pour sa supervision académique et son engagement constant envers la formation et la réussite des étudiants.

Je souhaite exprimer ma profonde gratitude à Monsieur EL ARCHI Nabil, encadrant au sein du Groupe OCP de Khouribga, ainsi qu'à l'ensemble du personnel, pour leur accueil chaleureux, leur disponibilité, leur professionnalisme et les conditions de travail favorables qu'ils m'ont offertes tout au long du projet. Leur accompagnement, leurs orientations méthodologiques et leur esprit de collaboration ont grandement contribué au bon déroulement et à la pertinence de cette étude.

Enfin, je remercie du fond du cœur ma famille et mes proches pour leur encouragement inconditionnel, leur patience et leur soutien moral, qui ont été d'une grande importance tout au long de cette aventure.

Résumé

Ce projet de fin d'études s'inscrit dans le cadre d'un apprentissage pratique de la **cybersécurité offensive**. Il a été réalisé au sein du **Groupe OCP – Khouribga** dans le but de concevoir un environnement virtuel sécurisé, permettant de simuler des scénarios d'attaques sur une machine vulnérable, tout en observant leur détection via un système de surveillance réseau.

L'infrastructure repose sur trois machines virtuelles configurées sous `VirtualBox` : une machine **Kali Linux** servant de poste d'attaque, intégrant des outils de reconnaissance et d'exploitation tels que `Nmap` et `Metasploit`, une machine **Metasploitable 2** volontairement vulnérable, et une machine **Security Onion** jouant le rôle de système de détection d'intrusions grâce aux IDS `Zeek`, `Suricata` et à la plateforme d'analyse `Kibana`.

Le scénario d'attaque mis en œuvre consiste à exploiter une faille de type*backdoor* dans le service FTP `vsftpd 2.3.4` sur le port `21`. Les étapes de l'expérimentation ont été les suivantes :

— Réaliser une phase de scan à l'aide de `Nmap` pour identifier les services exposés ;
— Exploiter les failles identifiées à l'aide de `Metasploit Framework` ;
— Obtenir un accès non autorisé à la machine cible et simuler une compromission ;
— Observer et analyser les alertes générées par `Security Onion` via ses interfaces de monitoring.

Ces expérimentations ont été réalisées dans un réseau isolé, garantissant un cadre éthique, sécurisé et reproductible.

Enfin, les résultats obtenus ont permis d'évaluer l'efficacité d'un système de détection d'intrusions (IDS) face à des comportements malveillants typiques, tout en approfondissant la compréhension des mécanismes d'attaque, de reconnaissance et de post-exploitation. Ce projet met ainsi en évidence la valeur pédagogique des laboratoires virtuels dans la formation à la cybersécurité offensive.

Liste des Abréviations

Abréviation	Définition
OCP	Office Chérifien des Phosphates
VM	Virtual Machine (Machine virtuelle)
IP	Internet Protocol (Protocole Internet)
IDS	Intrusion Detection System (Système de détection d'intrusion)
IPS	Intrusion Prevention System (Système de prévention des intrusions)
IPS	Intrusion Prevention System (Système de prévention d'intrusion)
SOC	Security Operations Center (Centre des opérations de sécurité)
SIEM	Security Information and Event Management (Gestion des événements et des informations de sécurité)
FTP	File Transfer Protocol (Protocole de transfert de fichiers)
DoS	Denial of Service (Déni de service)
DDoS	Distributed Denial of Service (Déni de service distribué)
MITM	Man In The Middle (Attaque de l'homme du milieu)
GUI	Graphical User Interface (Interface graphique utilisateur)
OS	Operating System (Système d'exploitation)
NSM	Network Security Monitoring

Introduction générale

À l'ère de la transformation numérique, la sécurité des systèmes d'information représente un enjeu stratégique majeur pour les entreprises et les institutions. L'augmentation continue des cybermenaces, telles que les attaques ciblées, les intrusions automatisées et l'exploitation de failles connues, impose aux organisations de mettre en œuvre des stratégies de protection proactives et efficaces. Dans ce contexte, la cybersécurité offensive s'impose comme un domaine incontournable, permettant de simuler des attaques dans un environnement maîtrisé afin d'identifier les vulnérabilités avant qu'elles ne soient exploitées par des acteurs malveillants.

Le présent projet, réalisé au sein du **Groupe OCP – Khouribga** dans le cadre de notre formation en sécurité des technologies de l'information, s'inscrit dans cette approche. Il consiste à concevoir un laboratoire virtuel sécurisé permettant de simuler des scénarios d'attaques sur une machine vulnérable, tout en observant leur détection via une solution de surveillance réseau. L'expérimentation a été menée dans un environnement isolé, en respectant les bonnes pratiques éthiques et techniques.

L'objectif principal de ce travail est de comprendre la logique d'une attaque informatique, de la phase de reconnaissance jusqu'à la post-exploitation, tout en évaluant la capacité d'un système de détection à identifier les comportements malveillants. Ce projet permet également de se familiariser avec des outils professionnels utilisés dans le domaine de la sécurité.

Le présent mémoire est structuré en cinq chapitres, comme suit :

- **Chapitre 1** : *Introduction et cadre du projet* ; ce chapitre présente le contexte général, la problématique de sécurité abordée, les objectifs visés ainsi que la démarche adoptée.
- **Chapitre 2** : *Présentation des outils utilisés* ; il décrit les environnements logiciels et matériels, ainsi que les technologies mobilisées pour la mise en œuvre du projet.
- **Chapitre 3** : *Mise en place de l'environnement expérimental* ; il détaille la configuration des machines virtuelles, le schéma réseau, les adresses IP attribuées et les tests de connectivité.
- **Chapitre 4** : *Simulation des attaques techniques* ; ce chapitre expose pas à pas l'attaques réalisée, sa configuration spécifique, les résultats obtenus et les observations associées.
- **Chapitre 5** : *Détection et analyse des résultats* ; il propose une interprétation des alertes générées, une analyse critique de la détection, ainsi que des pistes d'amélioration envisageables.

Table des matières

Remerciements **1**

Résumé **2**

Liste des Abréviations **3**

Introduction générale **4**

1 Introduction et Cadre du projet **10**
1.1 Introduction au domaine de la cybersécurité 10
1.2 Définitions des concepts clés 10
1.3 Problématique 11
1.4 Objectifs du projet 12
1.4.1 Objectif principal 13
1.4.2 Objectifs spécifiques 13
1.5 Méthodologie de travail 14
1.5.1 Analyse théorique et étude des outils 14
1.5.2 Mise en place de l'environnement virtuel 14
1.5.3 Réalisation des attaques 15
1.5.4 Analyse des résultats et détection 15
1.5.5 Documentation et synthèse 15

2 Présentation des outils utilisés **17**
2.1 Kali Linux : système d'attaque 17
2.1.1 Rôle dans l'architecture de test 17
2.1.2 Environnement préconfiguré pour le pentest 17
2.1.3 Outils d'analyse réseau 17
2.1.4 Outils d'exploitation de vulnérabilités 18
2.1.5 Autres outils notables 18
2.1.6 Pourquoi Kali ? 18
2.2 Metasploitable 2 : Machine vulnérable 18
2.2.1 Systèmes et services exposés 19
2.2.2 Utilisation dans notre environnement de test 19
2.2.3 Avantages pédagogiques 19
2.2.4 Limites connues 19
2.3 Security Onion : Plateforme de détection d'intrusion (IDS/NSM) 20
2.3.1 Architecture logicielle 20
2.3.2 Fonction IDS et NSM 20
2.3.3 Rôle dans notre architecture de test 20

2.3.4 Avantages pédagogiques 21
2.3.5 Limites potentielles 21
2.4 VirtualBox et Configuration Réseau 21
2.4.1 Présentation générale de VirtualBox 21
2.4.2 Modes de réseau disponibles dans VirtualBox 22
2.4.3 Outils réseau intégrés à VirtualBox 22
2.4.4 Choix des modes réseau pour notre environnement 22
2.4.5 Avantages de ce choix de configuration 23

3 Mise en place de l'environnement 25
3.1 Installation et préparation des machines virtuelles 25
3.1.1 Prérequis techniques 25
3.2 Configuration réseau des machines virtuelles 27
3.2.1 Configuration réseau de Kali Linux 27
3.2.2 Configuration réseau de Metasploitable 2 29
3.2.3 Configuration réseau de Security Onion 30
3.3 Attribution des adresses IP 31
3.3.1 Introduction 31
3.3.2 Plan d'adressage IP 32
3.3.3 Configuration IP sur Kali Linux 32
3.3.4 Configuration IP sur Metasploitable 2 33
3.3.5 Configuration IP sur Security Onion 34
3.4 Test de connectivité entre les machines virtuelles 35
3.4.1 Objectif des tests 35
3.4.2 Tests depuis Kali Linux 35
3.5 Vérification de l'accessibilité de l'interface SOC de Security Onion 37
3.5.1 Accès depuis la machine hôte (Windows) 37
3.5.2 Accès depuis Kali Linux 38

4 Simulation d'une attaque depuis Kali Linux 41
4.1 Introduction 41
4.2 Analyse de la cible avec Nmap 41
4.3 Choix de l'exploit approprié 43
4.3.1 Exploit 1 : vsFTPd 2.3.4 – Backdoor Command Execution 43
4.4 Exécution de l'attaque avec Metasploit 44
4.4.1 Étape 1 : Lancement de Metasploit 44
4.4.2 Étape 2 : Recherche du module 44
4.4.3 Étape 3 : Informations sur le module 45
4.4.4 Étape 4 : Affichage des options requises 46
4.4.5 Étape 5 : Configuration de l'adresse IP de la victime 46
4.4.6 Étape 6 : Exécution de l'exploit 47
4.4.7 Preuves d'accès au shell 48
4.4.8 Création d'un fichier de preuve 49
4.4.9 Blocage du terminal de l'utilisateur cible 50

5 Cinquième Chapitre 52

Conclusion Générale 53

Table des figures

3.1 Interface VirtualBox affichant les machines Kali, Metasploitable 2 et Security Onion . . . 26
3.2 Adaptateur 1 de Kali Linux configuré en mode Accès par pont . . . 27
3.3 Adaptateur 2 de Kali Linux configuré en réseau interne nommé `lab1` . . . 28
3.4 Adaptateur de Metasploitable 2 configuré en réseau interne nommé `lab1` . 29
3.5 Adaptateur 1 de Security Onion configuré en accès par pont . . . 30
3.6 Adaptateur 2 de Security Onion configuré en réseau interne `lab1` . . . 31
3.7 Interface eth0 de Kali Linux configurée avec 192.168.0.10 . . . 32
3.8 Interface eth1 de Kali Linux configurée avec 192.168.56.10 . . . 33
3.9 Interface eth0 de Metasploitable 2 configurée avec 192.168.56.20 . . . 33
3.10 Interface enp0s3 de Security Onion configurée avec 192.168.0.99 . . . 34
3.11 Adresse Web fournie pour accéder au SOC de Security Onion . . . 34
3.12 Test de ping depuis Kali Linux vers Metasploitable 2 . . . 36
3.13 Test de ping depuis Kali Linux vers Metasploitable 2 . . . 36
3.14 Test de ping depuis Kali Linux vers Security Onion via le réseau par pont . 37
3.15 Interface web de Security Onion accessible depuis la machine hôte (Windows) 38
3.16 Interface SOC accessible depuis Kali Linux via navigateur web . . . 39
3.17 Accès à la console SOC depuis Kali Linux . . . 39

4.1 Résultat du scan Nmap sur la machine Metasploitable 2 . . . 42
4.2 Résultat du scan Nmap sur la machine Metasploitable 2 . . . 42
4.3 Ouverture de Metasploit avec `msfconsole` . . . 44
4.4 Résultat de la recherche du module `vsftpd` . . . 45
4.5 Détails du module d'exploitation `vsftpd_234_backdoor` . . . 45
4.6 Options à configurer pour le module d'exploitation . . . 46
4.7 Définition de l'adresse IP de la victime avec `set RHOST` . . . 47
4.8 Lancement de l'exploit . . . 47
4.9 Affichage de la commande `ls` . . . 48
4.10 Affichage des commandes `pwd`, et `whoami` . . . 49
4.11 Modification des permissions . . . 49
4.12 Permission denied . . . 50
4.13 Apres la modification des permissions . . . 50
4.14 Blocage du terminal avec une boucle infinie . . . 51

Conclusion Générale

Ce projet avait pour objectif la mise en place d'une simulation d'attaque dans un environnement contrôlé, composée de trois machines virtuelles : **Kali Linux** (attaquant), **Metasploitable 2** (victime) et **Security Onion** (détection d'intrusion). À travers ce scénario, nous avons pu mettre en œuvre différentes compétences techniques en matière d'analyse des vulnérabilités, exploitation, élévation de privilèges, et observation de la détection via un système de surveillance réseau.

L'exploitation réussie d'une vulnérabilité du service `vsftpd` nous a permis d'accéder au système victime. Après obtention d'un shell, nous avons réalisé diverses opérations de reconnaissance et de post-exploitation, comme la création de répertoires, de fichiers, et la gestion des permissions, mettant en lumière les aspects essentiels de la sécurité des systèmes Linux. L'analyse des tentatives d'intrusion et leur détection dans Security Onion a complété notre démarche, en illustrant le rôle crucial des systèmes IDS dans une architecture de défense en profondeur.

Ce projet nous a permis de :

— Maîtriser la configuration d'un environnement de test sécurisé basé sur VirtualBox ;
— Comprendre le cycle complet d'une attaque : reconnaissance, exploitation, et post-exploitation ;
— Observer en temps réel les alertes générées par un système de détection d'intrusion ;
— Renforcer nos compétences en administration Linux, sécurité réseau, et analyse forensique ;
— Prendre conscience de l'importance de la sécurité préventive (mise à jour, gestion des services, permissions, etc.).

En somme, cette simulation constitue une excellente approche pédagogique pour appréhender les mécanismes d'attaque et de défense dans un réseau informatique. Elle renforce nos acquis théoriques par la pratique et nous prépare à mieux sécuriser les infrastructures informatiques dans un contexte professionnel réel.